

Contents

The Little Explorer	1
Product & Technical Documentation	1
Table of Contents	1
1. Executive Summary	2
2. Architecture Overview	2
3. Features — Web App	4
4. Features — iOS App	7
5. Cross-platform Comparison	9
6. Technical Stack	10
7. Authentication & Sessions	11
8. Backend & Infrastructure	12
9. Data Model	13
10. API Reference	14
11. Integrations / Third-party Services	15
12. Security	16
13. Compliance — RGPD & Strava	18
14. Observability & Audit	18
15. Engineering Decisions	19
16. Roadmap / Out of Scope	19
17. Glossary	20
Document End	21

The Little Explorer

Product & Technical Documentation

A personal multi-sport platform built as a Strava + Komoot alternative. Two surfaces — a Next.js web app and a native SwiftUI iOS app — sharing one Supabase backend.

Author — Florian Calabrese **Version** — 1.0 · May 2026 **Repos** - Web : <https://github.com/Calabroche/the-little-explorer> - iOS : <https://github.com/Calabroche/the-little-explorer-ios>

Table of Contents

1. Executive Summary
 2. Architecture Overview
 3. Features — Web App
 4. Features — iOS App
 5. Cross-platform Comparison
 6. Technical Stack
 7. Authentication & Sessions
 8. Backend & Infrastructure
 9. Data Model
 10. API Reference
 11. Integrations / Third-party Services
 12. Security
 13. Compliance — RGPD & Strava
 14. Observability & Audit
 15. Engineering Decisions
 16. Roadmap / Out of Scope
 17. Glossary
-

1. Executive Summary

The Little Explorer is a personal multi-sport tracking and analysis platform built as a deliberate alternative to Strava + Komoot. The backend is shared between two clients: a **Next.js 13 web app** deployed on Vercel and a **native SwiftUI iOS app** with watchOS companion.

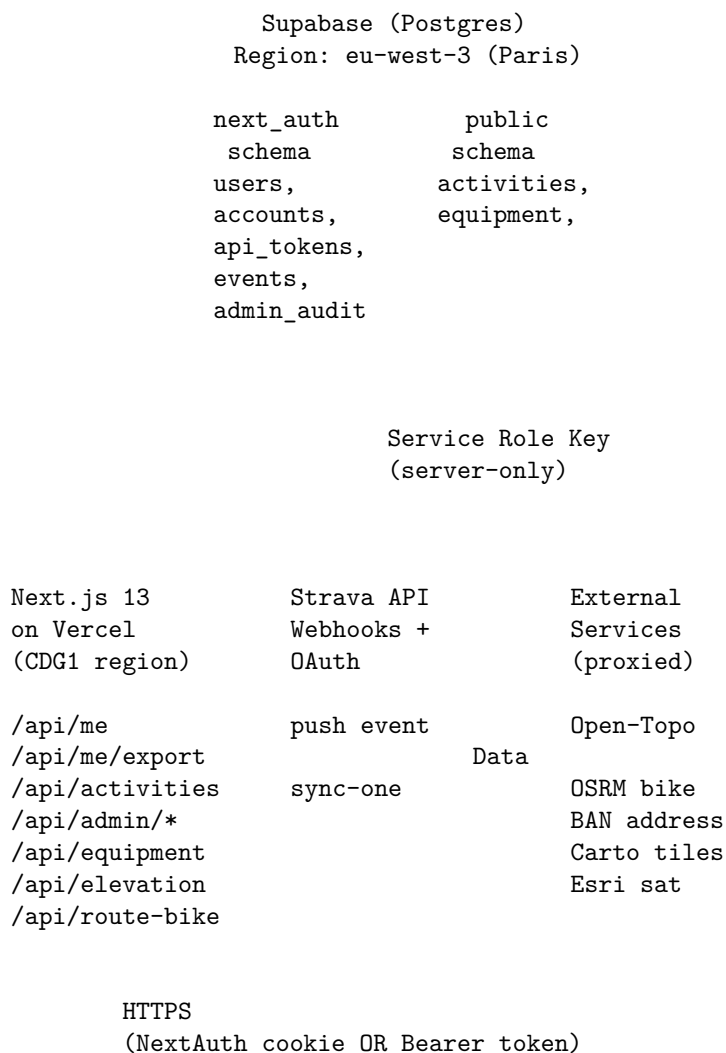
Target users — Florian (the author), his partner Helena, and a small circle of family and friends. Capped at 1–15 users by design. No app store distribution, no monetisation, no paid tier.

Core value — Gives the user the rich analysis tools Strava paywalls behind Premium (TSS, FTP curves, CTL/ATL/TSB, climb auto-detection, power estimation, year-in-review) without ads, without social bloat, without selling data.

Project metrics (May 2026) : - 6 weeks of intense iterative development - ~220 commits combined across two repos - 33+ numbered PRs on iOS, 20+ on web - 20+ surface features shipped - ~24,000 lines of code (TypeScript + Swift combined)

2. Architecture Overview

High-level diagram



Web Browser	iOS App
React + SWR	SwiftUI
Recharts	HealthKit
Leaflet maps	ActivityKit
next/font	MapKit + Watch

proxied requests

Two surfaces, one backend

Layer	Purpose
Web app	Analysis & planning. Rich charts, big screen, mouse + keyboard. Hosted on Vercel (Paris edge).
iOS app	Capture & glance. Live GPS recording, Live Activities, Apple Watch, HealthKit.
Backend	Single API surface, single Supabase Postgres. Strava sync (webhook + cron), elevation / routing / address proxies.

Repository structure (web)

```

the-little-explorer/
  src/
    app/
      api/
      admin/
      auth/native-done/
      settings/
      onboarding/
      privacy/
      terms/
      login/
      navigate/[id]/
      [...slug]/
    components/explorer/
      pages/
      tokens.ts
      Sidebar.tsx
      AnalysisPage.tsx
    lib/
      auth.ts
      api-auth.ts
      db.ts
      admin.ts
      rate-limit.ts
      events.ts
      audit.ts
      climbs.ts
      training-load.ts
      wrapped-video.ts
    components/Footer.tsx
  i18n/
    Next.js App Router
    REST + auth endpoints
    Admin dashboard pages
    iOS bearer-token handoff
    User settings
    3-step new-user flow
    Public privacy policy
    Public ToS
    Auth landing
    Turn-by-turn PWA
    Activity detail
    Main UI shell
    Each "tab" of the explorer
    Design tokens + Activity type
    Nav
    Activity detail (HR + slope chart, etc.)
    Shared business logic
    NextAuth config
    Bearer + cookie auth resolver
    Supabase admin client
    Admin email allowlist
    Token-bucket guard
    Event logging
    Admin audit log helper
    Climb auto-detector
    CTL/ATL/TSB computation
    Year-in-review MP4 export
    Global footer (Powered by Strava)
    FR/EN dictionaries

```

middleware.ts	Auth gate + onboarding redirect
public/	Static assets
supabase/schema.sql	Idempotent schema migrations
docs/	This document

Repository structure (iOS)

the-little-explorer-ios/	
LittleExplorer/	Main iOS app (SwiftUI)
App/	Bootstrapping
LittleExplorerApp.swift	@main
AppEnvironment.swift	Dependency container
RootView.swift	LoginView vs MainView gate
AppRouter.swift	Cross-tab nav
Features/	
Feed/	Activities tab
Tracking/	Track tab (live recorder)
Itinerary/	Planificateur tab
Navigation/	Turn-by-turn nav
Activities/	Activity detail + climbs
Analytics/	Analyses tab
Profile/	Profil tab + Settings
Services/	
APIClient.swift	HTTP client (bearer-auth)
SessionStore.swift	Keychain + UserDefaults token
LocationManager.swift	CoreLocation wrapper
HealthKitService.swift	HKWorkout + HKWorkoutRoute
HeartRateMonitor.swift	BLE GATT 0x180D wrapper
WatchSessionManager.swift	WCSession
RideActivityManager.swift	ActivityKit Live Activity
UI/	Reusable components
LittleExplorerLiveActivity/	WidgetKit extension
RideLiveActivity.swift	Lock-screen + Dynamic Island
LittleExplorerWatch/	watchOS companion
Shared/	Cross-target code
Models/	RideRecord, SportSubtype, etc.
GpxBuilder.swift	GPX 1.1 serializer
RideGpxBuilder.swift	GPX with timestamps + HR
project.yml	xcodegen config
sync.sh	One-shot pull/build/install

3. Features — Web App

3.1 Authentication & onboarding

Feature	Description
OAuth Google	NextAuth provider. Primary login. Email verified by Google.
OAuth Strava	Hand-rolled NextAuth provider (Strava deviates from OAuth2 standard — <code>client_secret_post</code> , comma-separated scopes, no PKCE).

Feature	Description
Onboarding 3 steps	New users land on /onboarding. Step 1: sport. Step 2: rider+bike weight, optional FTP. Step 3: connect Strava (skippable). Stores onboarded_at timestamp; middleware redirects until completed.
Logout from all devices	POST /api/me/logout-all bumps session_invalidated_at to invalidate all JWTs + revokes all bearer tokens.
Account deletion (RGPD art. 17)	DELETE /api/me revokes Strava token, then cascades delete user ☐ drops accounts / sessions / api_tokens / activities / equipment.
Multi-user with allowlist	ADMIN_EMAILS hardcoded set in src/lib/admin.ts.

3.2 Feed (home)

Feature	Description
Activity Calendar heatmap	6-month rolling heatmap, hover tooltip with slope/HR/speed/avg.
Last 5 stats card	Rolling-5 averages: duration, distance, elev, speed, HR, NP, TSS, w/kg.
Goals card	Configurable weekly km/D+/TSS targets with progress bars.
Training Program card	TSS-based recap of last 10 rides + 10 % rule explainer (cycling only).
Activity list	Newest first, infinite scroll, per-card mini-map preview.

3.3 Activity detail (/ [...slug])

Feature	Description
Header	Sport pill + title (Playfair Display serif) + location + date.
Stats grid	Duration / Distance / Avg / Max / Climb / Avg HR / Max HR / Calories.
FTP estimated card	Cycling only. Power-duration curve from best 20-min × 0.95.
HR + slope dual-axis chart	Composed chart with HR line + slope area, color-banded by gradient.
Speed chart	Area chart, peak-preserving downsampling.
Power chart	Computed client-side from speed + slope + rider/bike mass (CdA, Crr).
Elevation chart	Area, sticky scrub with haptic feedback on drag.
HR zones card	Time-in-zone bars Z1–Z5.
Route map	Leaflet with CARTO Positron / dark / satellite (Esri) basemaps.
Auto-detected climbs card	Algorithmic detection (≥ 500 m / ≥ 30 m / ≥ 3 % avg). Hover row ☐ highlights GPS segment on map. Side-by-side 80/20 layout.
VO₂max estimated card	From max HR / resting HR ratio.
Power summary card	NP, IF, VI, TSS, w/kg.
Climbing rates	VAM, max sustained grade, etc.

3.4 Planificateur (/planificateur)

Sub-tab	Description
Itinéraire	Komoot-style village-by-village builder. BAN address autocomplete, OSRM bike routing, elevation profile, loop toggle, auto-extend (reverse geocode), GPX export.
Plan	Multi-sport training plan engine. Cycling = km + D+ (TSS). Course = km + pace. Snow/Water/Indoor removed (UI clarity decision). 3:1 cycle + 2-week taper.
Auto	Route Builder — parameter-driven random route generator.
Suggestions	Curated Monts d'Or loops.

3.5 Analyses

Page	Description
Carte des parcours	All routes overlaid on one map, sport filter, auto-zoom on centroid.
Photos	Gallery from activity photo uploads.
FTP	Power-duration curve, FTP evolution (rolling-max best 20 × 0.95).
Comparer	Two-ride overlay on km axis, tappable card pickers.
Bilan	Year-in-review with 8+ animated cards. Configurable per year. Export as animated WebM video (new).
Charge	CTL / ATL / TSB curves with 5 zone-banded interpretation areas.
Matériel	Maintenance tracker — chain, brake pads, tires, etc. with wear bars per part.

3.6 Navigate (/navigate/[id])

Feature	Description
Turn-by-turn 3D	Full-screen Apple-Maps-style on the iPhone PWA.
Live nav state	Distance to next maneuver, voice prompts (iOS only), next-step arrow.
Background mode	Continues recording with screen locked.

3.7 Profile & Settings

Setting	Description
Identité — display name	Override the OAuth-provided name.
Profil cycliste	rider_kg, bike_kg, custom_ftp (overrides auto-derived).
Préférences	Dark mode toggle, langue FR/EN.
Strava	Re-sync button, disconnect button.
Mes données	Export RGPD (full JSON), Delete account, Logout-from-all-devices.
Compliance	“Powered by Strava” footer, /privacy + /terms pages publicly accessible.

3.8 Admin (allowlist-gated)

Page	Description
/admin	User list with email / provider / activity count / created.
/admin/metrics	Product analytics dashboard. KPI tiles, DAU 30-day bar chart, onboarding funnel, event-type breakdown, live tail (25 last events).

4. Features — iOS App

4.1 Authentication

Feature	Description
OAuth via ASWebAuthenticationSession	iOS bounces to the web's OAuth flow, gets back a Bearer token via littleexplorer://auth/done?token=...
Bearer token persistence	32 bytes crypto random base64url. Stored in Keychain with WhenUnlockedThisDeviceOnly accessibility.
90-day token expiry	expires_at stamped server-side. Tolerant fallback when the column doesn't exist (pre-migration).
Logout from all devices	Same backend as web; iOS calls POST /api/me/logout-all.

4.2 Five-tab navigation

Tab	Description
Activités	Feed (greeting + period stats + heatmap + Last5 + activity cards). Pull-to-refresh. Long-press card  delete (escape hatch).
Track	Live recorder with 20+ sport subtypes (roadCycling, MTB, gravel, running, trail, alpineSki, snowshoe, swimming, strength, HIIT, yoga, RPM, ...). Outdoor canvas = live map; indoor canvas = metrics-only screen.
Planificateur	Two-row picker: top = sport category (Vélo / Course), second = sub-feature tabs filtered per category.
Analyses	Carte / Photos / FTP / Compare / Bilan / Performances (Records + TSS Program).
Profil	Account card, Settings, Bluetooth Sensors, Diagnostics, Admin (allowlist).

4.3 Live Activity (Lock Screen + Dynamic Island)

Surface	Content
Lock Screen banner	Horizontal layout. Left: map polyline drawn in SwiftUI Canvas. Right: distance, duration, speed, HR.
Dynamic Island compact	Distance +  for active recording.
Dynamic Island expanded	Distance + duration + speed + HR.

Surface	Content
Dynamic Island minimal	Tiny  icon.

Note — `MKMapSnapshotter` for a real raster map requires App Group entitlement, which Personal Team free can't sign. The Canvas polyline projection is the workaround.

4.4 Activity detail

Same charts + sections as the web (HR/slope, speed, power, elevation, HR zones, climbs auto-detected, route map). Differences: - Charts: Swift Charts framework. - Maps: native MapKit. - Scrub: drag gesture with haptic feedback (`UISelectionFeedbackGenerator`). - Climbs interaction: tap a row to highlight the segment on the map below.

4.5 Track (live recorder)

Feature	Description
GPS quality filter	Rejects samples with <code>horizontalAccuracy > 30 m</code> or <code>> sport-realistic speed</code> .
Auto-pause	Per-sport low-speed threshold (cycling 3 km/h, walking 1, swim disabled). 8-second debounce. Clock freezes; polyline still ingests samples.
Sport-aware speed ceiling	90 km/h cycling, 28 running, 10 walking, 100 ski. Anything above = GPS jump, rejected.
HealthKit write	<code>HKWorkout</code> + <code>HKWorkoutRoute</code> on save. Apple Watch activity rings credited.
Strava upload	One-tap “Sauvegarder + envoyer sur Strava”. Custom GPX 1.1 serializer with per-point timestamps + Garmin HR extensions.
Local rides	Stored in <code>LocalRideStore</code> . Negative IDs (<code>-unixTimestamp</code>) so they never collide with Strava's positive IDs.

4.6 Navigate (turn-by-turn)

Feature	Description
Apple-Maps-style 3D Voice prompts	Pitched MapKit with route polyline. <code>AVSpeechSynthesizer</code> with <code>.playback + .duckOthers + mode: .voicePrompt</code> . Bypasses mute switch like Apple Maps. Ducks Spotify during announcement. 4 prompt levels: 1.2 km / 500 m / 150 m / 30 m. Toggle in Settings.
Background audio	<code>UIBackgroundModes: audio</code> so prompts continue with screen locked.

4.7 Apple Watch companion

Feature	Description
<code>HKWorkoutSession</code> <code>Vertical TabView</code> <code>WatchConnectivity</code>	Real workout with HR + distance. Metrics page + controls (pause / resume / stop). Synced to iPhone via <code>WCSession</code> .

4.8 Bluetooth Heart-Rate Sensor

Feature	Description
CoreBluetooth GATT	Scans for Heart Rate Service 0x180D, connects, subscribes to Heart Rate Measurement characteristic 0x2A37.
Pairing UI	Settings ☐ Bluetooth Sensors. RSSI-sorted list (strongest first).
Live BPM display	Big-number readout when connected. Optional battery level if sensor exposes 0x180F.
Inject into RideTracker	Each fresh BPM update goes into <code>sampledHeartRate[]</code> aligned with GPS time axis. Saved as <code>heartrate</code> stream on the RideRecord.

4.9 Diagnostics & observability

Feature	Description
In-app log viewer	Reads <code>OSLogStore</code> filtered to the app's subsystem. Time-range / level / category / text filters. Share-as-text export.
NSUncaughtException trap	Serializes name+reason+stack to UserDefaults before the process dies. Next launch re-emits at <code>.error</code> level so the log viewer picks it up.
HealthKit permission probe	Saves and deletes a 1-second dummy HKWorkout to detect Apple's hidden permission denial (Apple deliberately doesn't expose the real status).
Wipe local rides	Emergency control to clear all <code>LocalRideStore</code> data.

4.10 Profile & Settings

Same as web (display name, rider/bike weight, FTP, export, delete, logout-all). Plus: - **HealthKit toggle** with permission probe button. - **Bluetooth Sensors** — pairing UI for HR straps. - **Voice navigation** — toggle + test button. - **Powered by Strava** attribution cell.

5. Cross-platform Comparison

Category	Web	iOS
Auth Google/Strava	☐ NextAuth	☐ ASWebAuthenticationSession bouncing through web
Bearer token	issue (/auth/native-done)	consume (Keychain)
Feed	☐	☐
Activity detail	☐ Recharts	☐ Swift Charts
Climb auto-detection	☐	☐ Tap to highlight
Track recorder	☐	☐ 20+ subtypes
Live Activity	☐	☐ Lock Screen + Dynamic Island
Apple Watch	☐	☐
HealthKit write	☐	☐
BLE HR strap	☐	☐ CoreBluetooth
Voice prompts	☐	☐ AVSpeechSynthesizer
Auto-pause	☐	☐ Per-sport thresholds

Category	Web	iOS
GPS quality filter	☐	☐
Diagnostics in-app	☐	☐ OSLogStore + crash trap
Itinerary builder	☐ Leaflet	☐ MapKit
Plan d'entraînement	☐ Vélo + Course	☐ Vélo + Course
Compare two rides	☐	☐
FTP page	☐	☐
Bilan annuel	☐ + Video export	☐
CTL / ATL / TSB	☐ /charge	☐ Future
Maintenance tracker	☐ /équipement	☐ Future
Strava upload from local rides	☐ backend	☐
Settings parity	☐	☐
Admin	☐ /admin + /admin/metrics	☐ Placeholder
Privacy / Terms pages	☐ Public	☐ External links
Onboarding 3 screens	☐ Web flow	☐ Auto-marked on signin
Powered by Strava	☐ Footer	☐ Settings cell

6. Technical Stack

6.1 Web

Layer	Tech
Framework	Next.js 13.5 (App Router) — pinned to 13.x because Node 16.15.1 constraint (Next.js 14+ requires Node 18+).
Language	TypeScript strict mode.
UI	React 18 server components + client components. Inline styles using a tokens object (no Tailwind, no CSS-in-JS lib).
Charts	Recharts 3.8 (LineChart, AreaChart, ComposedChart, BarChart).
Maps	React-Leaflet (CARTO Positron + Esri satellite tiles).
Fonts	Playfair Display (serif headlines) + Space Grotesk (sans body) via Google Fonts CDN.
State	useState / useReducer / useMemo. No Redux.
i18n	SWR-style fetch with internal caching. Custom lightweight FR/EN dictionaries (src/i18n/dictionaries.ts).
Build	next build on Vercel. distDir env-configurable.

6.2 iOS

Layer	Tech
Frameworks	SwiftUI (no UIKit screens, native components only).
State	@Observable macro (iOS 17+). @MainActor isolation on UI-touching services.
Maps	MapKit (Map, MapPolyline, MapCamera, .mapStyle(.standard(elevation: .realistic))).
Charts	Swift Charts (Chart, LineMark, AreaMark, BarMark, RuleMark).

Layer	Tech
Health	HealthKit (HKWorkoutBuilder, HKWorkoutRouteBuilder, HKQuantitySample).
Location	CoreLocation (CLLocationManager, kCLLocationAccuracyBest, .fitness activity type, allowsBackgroundLocationUpdates).
Bluetooth	CoreBluetooth (CBCentralManager, GATT service 0x180D).
Live Activities	ActivityKit (Activity.request, lock-screen banner + Dynamic Island).
Watch	WatchConnectivity (WCSession).
Audio	AVFoundation (AVSpeechSynthesizer, AVAudioSession).
Diagnostics	OSLog + OSLogStore for in-app log viewer.
Persistence	NSUncaughtExceptionHandler for crash trap.
Project	Keychain (SecItem) + UserDefaults (mirror).
CI	xcodegen (project.yml). No .xcodeproj in git.
Signing	GitHub Actions builds only (no automated tests yet). Personal Team free (Y7M9YY3LQJ). No paid Apple Developer Program.

6.3 Backend infrastructure

Component	Detail
Hosting	Vercel (CDG1 Paris region for serverless functions).
Database	Supabase Postgres in eu-west-3 (Paris).
Auth	NextAuth 4 JWT strategy (not database) so Edge middleware can decode without DB roundtrip.
Email	None. Notifications via in-app + console.log to Vercel.
Cron	GitHub Actions cron: '* / 15 * * * *' posts to /api/strava/sync as a backstop to Strava webhooks.
Logs	Vercel Functions logs (console.log / error). No SIEM.

7. Authentication & Sessions

7.1 OAuth providers

Google

- Standard OIDC via next-auth/providers/google.
- Verified email used as unique key.
- No special scopes — just openid email profile.

Strava (custom)

- Hand-rolled NextAuth provider because Strava deviates from OAuth2 standard:
 - token_endpoint_auth_method = 'client_secret_post' (Strava expects secret in body, not Basic auth).
 - checks: ['state'] only (Strava ignores PKCE).
 - Comma-separated scopes instead of space-separated.
 - athlete object in token response (no separate userinfo endpoint).
- Scopes: read,activity:read_all.
- Refresh token persisted in next_auth.accounts.refresh_token (encrypted at rest by Supabase).

7.2 Session strategy

- **NextAuth JWT** (`session: { strategy: 'jwt' }`) — works in Edge runtime for the middleware auth gate.
- **JWT contents:** `uid`, `athleteId`, `iat`, `onboardedAt`.
- **Refresh:** every request, the JWT callback re-fetches `session_invalidated_at` + `onboarded_at` from the user row. If the JWT's `iat` predates the invalidation, fields are stripped $\square$ `middleware` $\square$ `/login`.

7.3 iOS Bearer tokens

- 32 bytes crypto random $\square$ base64url-encoded (43 chars).
- Issued at `/auth/native-done` after OAuth bounces back through `ASWebAuthenticationSession`.
- Delivered to the iOS app via the `littleexplorer://auth/done?token=...` URL scheme.
- Stored in iOS Keychain with `kSecAttrAccessibleWhenUnlockedThisDeviceOnly`.
- 90-day expiry stamped server-side; `api-auth.ts` filters expired rows.
- Revocable via `revoked_at` (logout-from-all-devices and user-initiated rotation).

7.4 Authentication routes (`/api/auth/[...nextauth]`)

Standard NextAuth catch-all: `signin`, `callback`, `csrf`, `session`, `signout`, `providers`.

8. Backend & Infrastructure

8.1 Vercel deployment

Aspect	Configuration
Region	CDG1 (Paris) — serverless functions.
Runtime	Node.js 18 (Edge for middleware, Node for API routes).
Build	<code>next build</code>
Env vars	<code>NEXTAUTH_URL</code> , <code>NEXTAUTH_SECRET</code> , <code>GOOGLE_CLIENT_ID</code> , <code>GOOGLE_CLIENT_SECRET</code> , <code>STRAVA_CLIENT_ID</code> , <code>STRAVA_CLIENT_SECRET</code> , <code>STRAVA_VERIFY_TOKEN</code> , <code>STRAVA_WEBHOOK_SECRET</code> , <code>SUPABASE_URL</code> , <code>SUPABASE_SERVICE_ROLE_KEY</code> , <code>SUPABASE_JWT_SECRET</code> .
Analytics	Vercel Analytics + Speed Insights (anonymous Core Web Vitals).

8.2 Supabase

- Postgres 15.
- Two schemas: `next_auth` (NextAuth Supabase adapter) + `public` (our domain).
- Encryption at rest enabled.
- Service role key never bundled client-side — exclusively in Vercel env.
- Point-in-time recovery available (paid tier).

8.3 Strava webhook

- Two responsibilities:
 1. **GET** subscription handshake — replies `{"hub.challenge": token}` to Strava's verification call.
 2. **POST** live events — dispatches by `object_type` + `aspect_type`:
 - `activity.create` / `activity.update` $\square$ `fire-and-forget` `/api/strava/sync-one`
 - `activity.delete` $\square$ drop from `public.activities`
 - `athlete.update` with `updates.authorized: false` $\square$ null out `athlete_id` + drop strava accounts row.
- Constant-time string equality on the verify token (anti-timing-attack).

- Webhook ack < 1 s (Strava retries if > 2 s). Heavy work runs in a separate function invocation that survives the handler's return.

8.4 GitHub Actions cron (backstop)

- Workflow `.github/workflows/sync.yml` — cron: `'*/15 * * * *'`.
 - Calls `/api/strava/sync` server-side. Idempotent.
 - Picks up activities that the webhook missed (e.g. Vercel function timeout).
-

9. Data Model

9.1 next_auth schema (extensions on top of NextAuth's default adapter)

```
-- users - our extension columns marked with comments
create table next_auth.users (
  id          uuid primary key,
  name        text,
  email       text unique,
  "emailVerified" timestampz,
  image       text,
  -- Extension columns
  athlete_id  bigint unique,
  strava_scope text,
  rider_kg    numeric(5,2),
  bike_kg     numeric(5,2),
  custom_ftp  integer,
  created_at  timestampz default now(),
  onboarded_at timestampz,
  session_invalidated_at timestampz
);

-- api_tokens - iOS bearer auth
create table next_auth.api_tokens (
  id          uuid primary key,
  user_id     uuid not null references next_auth.users(id) on delete cascade,
  token       text not null unique,
  label       text,
  created_at  timestampz default now(),
  last_used_at timestampz,
  revoked_at  timestampz,
  expires_at  timestampz
);

-- events - product analytics
create table next_auth.events (
  id          bigserial primary key,
  user_id     uuid references next_auth.users(id) on delete set null,
  event_type  text not null,
  properties  jsonb default '{}',
  ip          text,
  user_agent  text,
  occurred_at timestampz default now()
);

-- admin_audit - admin write actions (forensic trail)
```

```
create table next_auth.admin_audit (
  id          uuid primary key,
  actor_id    uuid references next_auth.users(id) on delete cascade,
  action      text not null,
  target_user_id uuid references next_auth.users(id) on delete set null,
  payload     jsonb,
  ip          text,
  created_at  timestampz default now()
);
```

9.2 public schema (domain tables)

```
-- activities - Strava-synced + local rides
create table public.activities (
  id          bigint primary key,
  user_id     uuid not null references next_auth.users(id) on delete cascade,
  sport       text not null,
  original_type text,
  title       text,
  start_date  timestampz not null,
  duration_min integer,
  distance_km numeric(8,2),
  elevation_m integer,
  payload     jsonb not null, -- GPS, altitude, HR, speed streams
  created_at  timestampz default now()
);

-- bike_equipment - maintenance tracker
create table public.bike_equipment (
  id          uuid primary key,
  user_id     uuid not null references next_auth.users(id) on delete cascade,
  name        text not null,
  kind        text not null, -- chain, brake_pads, tires, ...
  installed_at timestampz default now(),
  installed_at_km numeric(10,2) default 0,
  lifetime_km integer default 3000,
  replaced_at timestampz,
  notes       text,
  created_at  timestampz default now()
);
```

9.3 Foreign-key cascade map

Every child table has ON DELETE CASCADE referencing next_auth.users(id). A single DELETE FROM next_auth.users WHERE id = ? purges: - accounts (OAuth providers) - sessions - api_tokens (bearer) - events - admin_audit (set null on target_user_id, cascade on actor_id) - activities - bike_equipment

10. API Reference

Route	Method	Auth	Rate-limit	Body cap	Description
/api/auth/[...next_auth]	any	public	—	—	NextAuth catch-all
/api/auth/native-oidc	GET (page)	session cookie	—	—	iOS bearer token issuance

Route	Method	Auth	Rate-limit	Body cap	Description
/api/me	GET	session or bearer	60/min/user	—	Read profile + effective settings
/api/me	PATCH	session or bearer	30/min/user	implicit	Update rider/bike/FTP/name
/api/me	DELETE	session or bearer	30/min/user	—	RGPD art. 17 delete
/api/me/export	GET	session or bearer	5/min/user	—	RGPD art. 20 export (JSON)
/api/me/disconnect-strava	POST	session or bearer	—	—	Unlink Strava (no data loss)
/api/me/logout-all	POST	session or bearer	—	—	Invalidate all sessions
/api/me/onboarding	POST	session or bearer	30/min/user	—	Onboarding events + complete
/api/activities	GET	session or bearer	—	—	List user activities
/api/admin/users	GET	admin email	—	—	Admin user list
/api/admin/metrics	GET	admin email	—	—	Product analytics
/api/equipment	GET	session or bearer	60/min/user	—	List bike parts + wear ratios
/api/equipment	POST	session or bearer	30/min/user	5 KB	Add a part
/api/equipment	PATCH	session or bearer	30/min/user	5 KB	Update / mark replaced
/api/equipment	DELETE	session or bearer	30/min/user	—	Remove a part
/api/strava-webhook	GET	Strava verify token	—	—	Subscription handshake
/api/strava-webhook	POST	Strava verify token	—	implicit	Live event delivery
/api/strava/sync	POST	session	—	—	Manual sync trigger
/api/strava/sync	POST	shared secret	—	—	Single activity sync (webhook fan-out)
/api/strava/upload-activity	POST	session or bearer	—	implicit	Push iOS local ride to Strava
/api/elevation	POST	public	60/min/IP	50 KB	Open-Topo Data proxy
/api/route-bike	POST	public	30/min/IP	10 KB	OSRM cycling proxy
/api/commune-search	GET	public	60/min/IP	—	BAN address proxy

11. Integrations / Third-party Services

11.1 Identity

Service	Purpose	Method
Google OAuth	Primary login	NextAuth provider next-auth/providers/google
Strava OAuth	Activity sync provider	Custom NextAuth provider (deviates from standard OAuth2)

11.2 Activity data

Service	Purpose	Endpoint
Strava API	Pull activities + streams	GET /api/v3/activities/{id}/streams
Strava Webhook	Real-time push notifications	Subscribed once via POST /push_subscriptions
Strava Upload	Push iOS-recorded rides	POST /api/v3/uploads (multipart)
Strava Deauthorize	Revoke our token on user delete	POST /oauth/deauthorize

11.3 Mapping & routing

Service	Purpose	Notes
OSRM (routed-bike)	Bike routing	routing.openstreetmap.de/routed-bike/rout — community-run, no key
Open-Topo Data (eudem25m)	Elevation profile	25m DEM Europe, 1 call/sec / 1000 calls/day free
BAN (Base Adresse Nationale)	French address search + reverse geocode	api-adresse.data.gouv.fr — government, no key, no quota
CARTO Positron / Dark	Light + dark basemap tiles	basemaps.cartocdn.com
Esri World Imagery	Satellite basemap	server.arcgisonline.com/...World_Imagery/

11.4 Infrastructure

Service	Purpose
Vercel	Hosting, edge middleware, serverless functions, analytics
Supabase	Postgres + auth schema
GitHub Actions	15-min cron backstop for Strava sync, CI builds

11.5 Native iOS (no third-party services, all OS frameworks)

CoreLocation, CoreBluetooth, MapKit, HealthKit, ActivityKit, WatchConnectivity, AVFoundation, SwiftUI Charts.

12. Security

12.1 HTTP response headers (live on Vercel)

Header	Value	Purpose
Strict-Transport-Security	max-age=63072000; includeSubDomains; preload	Force HTTPS for 2 years post-first-visit

Header	Value	Purpose
X-Frame-Options	DENY	Anti-clickjacking
Content-Security-Policy	frame-ancestors 'none'	Modern equivalent of X-Frame-Options
X-Content-Type-Options	nosniff	Anti MIME-guessing
Referrer-Policy	strict-origin-when-cross-origin	Limit referer leakage on outbound links
Cross-Origin-Opener-Policy	same-origin	Spectre mitigation + window.opener isolation
Cross-Origin-Resource-Policy	same-origin	Anti-fingerprinting logged-in state
Permissions-Policy	camera=(), microphone=(), geolocation=(self), ...	Deny all sensors except geolocation for nav

12.2 Authentication hardening

- **OAuth-only** — no passwords to bruteforce or leak.
- **JWT signed** with NEXTAUTH_SECRET (server-only).
- **Bearer tokens** crypto random, 256 bits of entropy.
- **Token expiration** 90 days on bearer tokens.
- **Logout-from-all** via session_invalidated_at JWT cutoff + revoked_at bearer revocation.
- **Constant-time string comparison** on the Strava webhook verify token.

12.3 Rate limiting

Per-IP for public proxies (elevation, route-bike, commune-search). Per-user for authenticated routes: - authedRead (60/min) on /api/me GET, /api/equipment GET - authedWrite (30/min) on /api/me PATCH/DELETE, /api/equipment POST/PATCH/DELETE, /api/me/onboarding - heavyRead (5/min) on /api/me/export

Implementation: in-memory token bucket per process. Vercel-instance-scoped (effective ceiling = instances × capacity, fine for our scale).

12.4 Body size guards

- /api/elevation: 50 KB cap (100 [lat,lng] pairs = 2 KB).
- /api/route-bike: 10 KB cap.
- /api/equipment: 5 KB cap.
- Implementation checks Content-Length header before req.json() so a 50 MB POST is rejected with 413 before any bytes processed.

12.5 iOS-side hardening

- **Keychain accessibility** kSecAttrAccessibleWhenUnlockedThisDeviceOnly — token unreadable when phone locked, never synced via iCloud, never travels with backup.
- **App Group entitlement** deliberately NOT used (Personal Team free can't sign).
- **Bluetooth permission** explicit NSBluetoothAlwaysUsageDescription.

12.6 Decisions deliberately NOT made

Item	Reason
Full Content-Security-Policy	Leaflet / Recharts / next/font use inline styles; full CSP would break without a Report-Only audit pass first
Certificate pinning iOS	2h+ of code for marginal value at 15-user scale
WAF Cloudflare	Vercel already has DDoS basics
SAST in CI	Low-value at this scale

Item	Reason
IP allowlist for /admin 2FA	Single admin email, low risk OAuth provider (Google) handles 2FA on its side

13. Compliance — RGPD & Strava

13.1 RGPD

Right (article)	Implementation
Art. 13 (information)	/privacy and /terms pages publicly accessible without login
Art. 15 (access)	User sees all their data in the app + can export via art. 20
Art. 16 (rectification)	Settings page (rider/bike/FTP/name editable)
Art. 17 (erasure)	DELETE /api/me cascades all child tables + revokes Strava token
Art. 20 (portability)	GET /api/me/export returns full JSON
Art. 21 (objection)	OAuth disconnect button doesn't require account deletion

Tokens encrypted at rest by Supabase. EU-only data residency (Supabase eu-west-3, Vercel cdg1).

13.2 Strava API Agreement

Requirement	Status
“Powered by Strava” branding	☐ Footer (web) + Settings cell (iOS), official orange #FC5200
Privacy policy URL	☐ /privacy (public, indexed)
Terms of service URL	☐ /terms (public, indexed)
No redistribution of Strava data to third parties	☐ Single-user views only
Handle deauthorization webhook	☐ object_type=athlete + updates.authorized=false ☐ null out linkage
Promptly remove deleted activities	☐ aspect_type=delete webhook handled
No commercial use without Strava approval	☐ Personal use only, no app store, no monetisation
Single Athlete by default	☐ Default 1-athlete limit; increase requested by email (see ops note)

14. Observability & Audit

14.1 Event logging (next_auth.events)

8 instrumented event types: - `signin` — every successful sign-in - `signup` — first sign-in for a user (derived from age < 60s) - `first_sync` — user's first Strava activity synced - `export` — /api/me/export 2xx - `disconnect_strava`, `logout_all`, `delete_account` - `strava_webhook_received` / `strava_webhook_synced` (for sync success rate) - `onboarding_*` (6 events covering the funnel) - `rate_limited` (when a route hits the 429 threshold)

14.2 Admin audit log (`next_auth.admin_audit`)

Scaffolded for write actions on `/admin`. Currently no admin write actions exist; the helper `logAdminAction()` is ready for the next admin feature.

14.3 Metrics dashboard (`/admin/metrics`)

KPI tiles, 30-day DAU bar chart, onboarding funnel cards, top events 7-day breakdown, sync success rate, live tail of 25 last events. Admin allowlist only.

14.4 iOS in-app diagnostics

OSLogStore-backed log viewer with filters. `NSUncaughtException` trap persists crash data across launches.

15. Engineering Decisions

Decision	Rationale
Two surfaces, one backend	Same data, different affordances. Web = analysis (big screen), iOS = capture (sensors). Don't force feature parity.
NextAuth JWT not database session	Edge middleware needs to decode without DB roundtrip. Saves ~50ms per request.
Local ride IDs negative	Zero-cost dedupe vs Strava's positive IDs without a schema migration.
Hand-rolled GPX serializer	100 lines beats a 50-LOC dep tree.
Custom Strava OAuth provider	Strava deviates from OAuth2 standard. Off-the-shelf clients fail.
No App Group iOS	Personal Team free can't sign it. Reverted PR #15.
Canvas polyline for Live Activity	Can't host MapKit in a WidgetKit extension. App Group blocked.
Strict climb thresholds (500m/30m/3%)	Better 1-5 real climbs than 25 micro-kickers. Documented via NB on the card.
GPS quality filter	Reject <code>horizontalAccuracy > 30m</code> + sport-realistic speed ceiling. Prevents the 28 km/h walk bug.
Auto-pause per-sport thresholds	Cycling 3 km/h, swim disabled. Avoids dragging average down on red lights.
MediaRecorder, not <code>ffmpeg.wasm</code>	10 MB WASM bundle slow on iOS Safari. WebM accepted by social platforms now.
No tests on iOS	CI builds, type system catches most. Investment goes to features.
TypeScript strict on web	Different bug profile; strict mode catches real issues.

16. Roadmap / Out of Scope

16.1 Shipped but improvable

- **Multi-language:** only FR/EN. IT/ES/DE not implemented.
- **Units preference:** km/miles toggle deferred. Touches every formatter.
- **Reconnect-on-launch** for BLE HR (last-paired UUID persistence).

16.2 Blocked by Apple Developer Program (paid \$99/yr)

- **Race countdown widget** (Lock Screen) — needs App Group entitlement.
- **Apple Music integration** — needs MusicKit entitlement.
- **Push notifications** — needs APNs setup with paid team.

16.3 Out of scope by design

- **Social feed / kudos / comments** — explicit anti-Strava stance.
- **Real-time ride sharing** — privacy + complexity.
- **Voice prompts for nav** ☐ now shipped.
- **Offline tile cache** — storage cost + most rides start with signal.
- **Bluetooth power meter** ☐ shipped HR strap; power deferred but pattern proven.
- **Pluggable AI ride coach** — interesting but requires sustained dev focus.

16.4 Next plausible direction

- iOS port of /equipment (maintenance tracker, read-only view).
- iOS port of /charge (CTL/ATL/TSB curves).
- Email digest weekly (Resend / Postmark, ~100/month free).
- AI-generated activity titles (Anthropic API, \$20/month cap).

17. Glossary

Term	Meaning
TSS	Training Stress Score. 100 = an hour at FTP. Coggan's load measure.
FTP	Functional Threshold Power. The wattage you can sustain for 1 hour.
NP	Normalized Power. Variability-weighted average power.
IF	Intensity Factor. NP / FTP.
CTL	Chronic Training Load. 42-day EWMA of daily TSS. ≈ "fitness".
ATL	Acute Training Load. 7-day EWMA of daily TSS. ≈ "fatigue".
TSB	Training Stress Balance. CTL – ATL. ≈ "form today".
GPX	GPS Exchange Format. XML schema for trace data.
GATT	Generic Attribute Profile. Bluetooth LE data model.
HRMS	Heart Rate Measurement Service. Bluetooth SIG service UUID 0x180D.
OSRM	Open Source Routing Machine. The router behind our bike routing.
BAN	Base Adresse Nationale. French government's address database.
DEM	Digital Elevation Model. The grid of altitudes Open-Topo Data uses.
EWMA	Exponentially Weighted Moving Average.
PWA	Progressive Web App. Our /navigate/[id] page when added to iOS home screen.
JWT	JSON Web Token. NextAuth session format.
APNs	Apple Push Notification service. Out of scope (paid Apple Dev Program).
SIG	Bluetooth Special Interest Group. The standards body.

Term	Meaning
RSSI	Received Signal Strength Indicator. BLE distance proxy.

Document End

Generated as a snapshot of the May 2026 state of The Little Explorer. For the latest, see the repo READMEs and commit history.

Export to PDF :

Option A - Pandoc (best quality, requires LaTeX)

```
pandoc PRODUCT_DOC.md -o PRODUCT_DOC.pdf \
  --pdf-engine=xelatex \
  --variable mainfont="Helvetica" \
  --variable geometry:margin=2cm \
  --toc
```

Option B - Browser print

Open in Chrome/Safari, Cmd+P, "Save as PDF"

Option C - VS Code

Install "Markdown PDF" extension, right-click → Export PDF